

BONUS 1: INTERPRETARE DATI HTTP E DNS PER ISOLARE L'ATTORE DELLA MINACCIA

OBIETTIVI

Lo scopo è esaminare i log di uno sfruttamento di vulnerabilità documentate HTTP e DNS.

- Parte 1: Investigare un Attacco di SQL Injection.
- Parte 2: Investigare l'Esfiltrazione di Dati DNS.

AMBIENTE

In ambiente virtuale Security Onion si VirtualBox.

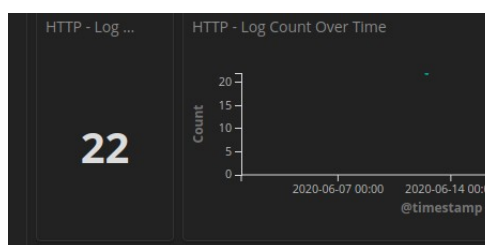
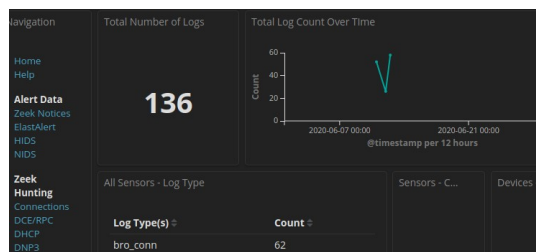
PARTE 1: INVESTIGARE UN ATTACCO DI SQL INJECTION

1) Dopo aver avuto accesso alla macchina ho aperto il terminale per controllare lo stato dei servizi con il comando `sudo so-status` e risultano tutti attivi.

```
File Edit View Search Terminal Help
analyst@SecOnion:~$ sudo so-status
[sudo] password for analyst:
status: securityonion
* sgul server [ OK ]
status: seconion-import
* pcap_agent (sgul) [ OK ]
* snort_agent-1 (sgul) [ OK ]
* barnyard2-1 (spooler, unified2 format) [ OK ]
status: Elastic stack
* so-elasticsearch [ OK ]
```

2) Ho poi aperto Kibana, dove ho cambiato l'intervallo di tempo in modo che coincida con gli alert dell'attacco avvenuto a giugno 2026.

Il numero di log rilevati per il mese di giugno 2026 sono 136, di questi gli http sono 22.



Qual è l'indirizzo IP sorgente? Qual è l'indirizzo IP destinazione? Qual è il numero di porta destinazione? L'IP sorgente 209.165.200.227, l'IP di destinazione 209.165.200.235 e la porta di destinazione è la 80.

HTTP - Source IP Address		HTTP - Destination IP Address	
IP Address	Count	IP Address	Count
209.165.200.227	22	209.165.200.235	22

HTTP - Destination Port (Vertical Bar Chart)	
Port	Count
80	22
Rows per page: 20	

Qual è il timestamp del primo risultato? Qual è il tipo di evento? Cosa è incluso nel campo message? Questi sono dettagli sulla richiesta HTTP GET fatta dal client al server. Concentrati specialmente sul campo url nel testo del messaggio. Qual è il significato di queste informazioni?

L'evento secondo il timestamp è stato registrato il 12 giugno 2020 alle 21:30:09.445 e si tratta di una richiesta GET. Più precisamente si tratta di un attacco di tipo SQL injection alla pagina web <http://209.165.200.235/mutillidae/index.php?page=user-info.php>, per ottenere le credenziali di accesso alle carte di credito.

3) Ho poi cliccato un link presente in alert_id nel primo log per aprire la scheda capME! Contenente una trascrizione pcap. Poi con Ctrl+F ho evidenziato la parola username.

```
DST: 24
DST: <b>Username=</b>8242325748474749<br>
DST:
DST: 17
DST: <b>Password=</b>461<br>
DST:
DST: 22
DST: <b>Signature=</b>2016-03-01<br><p>
DST:
DST: 24
DST: <b>Username=</b>7725653200487633<br>
DST:
DST: 17
DST: <b>Password=</b>230<br>
DST:
DST: 22
DST: <b>Signature=</b>2017-06-01<br><p>
DST:
DST: 24
DST: <b>Username=</b>1234567812345678<br>
DST:
DST: 17
DST: <b>Password=</b>627<br>
DST:
DST: 22
DST: <b>Signature=</b>2018-11-01<br><p>
DST:
DST: 3
DST: <p>
```

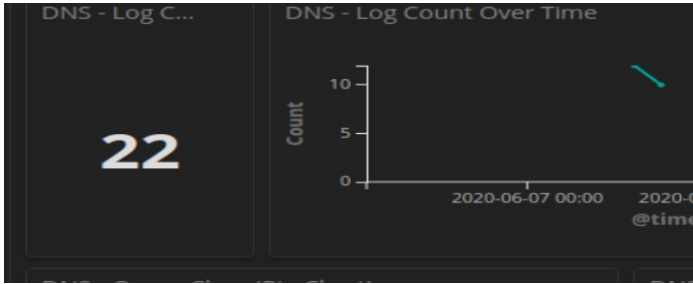
Cosa vedi più avanti nella trascrizione riguardo ai nomi utente? Fornisci alcuni esempi di nome utente, password e firma che sono stati esfiltrati.

Vedo che l'attacco è andato a buon fine e il server restituisce: username, password e firme.

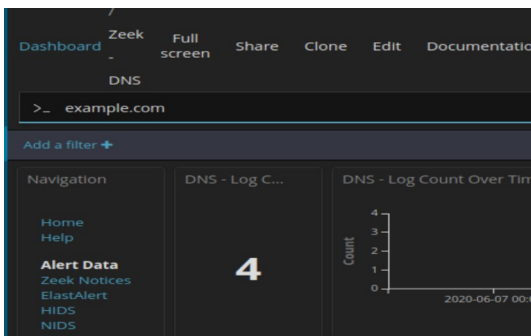
Username / Carta	Password	Firma / Scadenza
4444111122223333	745	2012-03-01
7746536337776330	722	2015-04-01
8242325748474749	461	2016-03-01
7725653200487633	230	2017-06-01
1234567812345678	627	2018-11-01

PARTE 2: ANALIZZARE L'ESFILTRAZIONE DNS

1) Sempre dalla dashboard di kibana ho filtrato i log DNS, che risultano essere 22.



2) Facendo un'analisi si notano query che hanno sottodomini insolitamente lunghi collegati a ns.example.com. Per investigare ulteriormente ho filtrato nella barra di ricerca example.com, ottenendo 4 risultati.



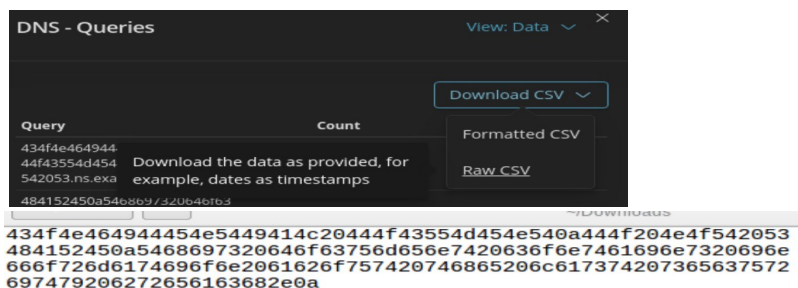
Registra gli indirizzi IP del client e del server DNS.

IP CLIENT: 192.168.0.11

IP SERVER: 209.165.200.235

DNS - Client		DNS - Server	
Client	Count	Server	Count
192.168.0.11	4	209.165.200.235	4

3) Ho scaricato la query DNS sul link di download Export: Raw e ho modificato il file su editor per togliere la parte non in esadecimale.



4) Subito dopo ho decodificato la stringa in esadecimale da terminale grazie al comando `xxd -r -p "DNS - Queries.csv" > secret.txt`

```
analyst@SecOnion:~/Downloads$ xxd -r -p "DNS - Queries.csv" > secret.txt
analyst@SecOnion:~/Downloads$ cat secret.txt
CONFIDENTIAL DOCUMENT
DO NOT SHARE
This document contains information about the last security breach.
analyst@SecOnion:~/Downloads$
```

I sottodomini delle query DNS erano sottodomini? Se no, qual è il testo?

No non erano sottodomini legittimi, ma stringhe di dati codificate in esadecimale inserite di nascosto per offuscare il testo reale. Il testo in chiaro è: CONFIDENTIAL DOCUMENT DO NOT SHARE This document contains information about the last security breach.

Cosa implica questo risultato riguardo a queste particolari richieste DNS? Qual è il significato più ampio?

Questo dimostra che è stato fatto un DNS tunneling (esfiltrazione di dati via DNS). Invece di usare le query DNS per risolvere gli indirizzi web, sono stati spezzetati e nascosti dati sensibili all'interno delle richieste inviate ad un server dell'attaccante.

Cosa potrebbe aver creato queste query DNS codificate e perché è stato scelto il DNS come mezzo per esfiltrare dati?

Le ha create uno script o da un malware progettato per raccogliere, codificare e trasmettere informazioni. È stato scelto perché il DNS è un protocollo normalmente utilizzato nelle reti, quindi può risultare meno sospetto.